

WAP protège la visibilité. Il faut aussi protéger les octets.

Le banc a montré qu'un lecteur autorisé sur une table pouvait atteindre les fichiers d'un candidat non publié, même après retrait de sa branche. La cible doit contrôler l'accès à une édition et à tous ses objets.

CHEMIN REPRODUIT DANS LE BANC

Main reste intact ; la confidentialité staging échoue

OBSERVÉ

Lecteur : table.select

Autorisation au niveau de la table



OBSERVÉ

Métadonnées + signer

Le snapshot staging reste découvrable



ÉCHEC REPRODUIT

GET des objets non publiés

Accès aussi après retrait de la branche

CHEMIN CIBLE À QUALIFIER

Identité + édition + fermeture de fichiers autorisés

CIBLE

Identité et politique

Utilisateur, tenant, édition demandée



CIBLE

Service de lecture / PEP

Vérifie édition et fermeture d'objets



CIBLE

Accès objets limité

Données, manifests, deletes, statistiques

CONTRAINTES DU MODÈLE NATIF

Autre frontière : le droit de commit

table.modify permet aussi can_commit et can_drop. Un worker générique ne doit pas le recevoir.

Rouge : comportement reproduit dans le banc local · Bleu : frontière proposée, encore à qualifier.

WAP protège la visibilité. Il faut aussi protéger les octets.

Échec observé + correction proposée · 2 octobre 2026 · L'HTML associé contient tous les blocs, les scénarios et les références.

La confidentialité a échoué dans le banc

Échec reproduit · Main reste inchangé ; les octets du candidat sont lisibles avant et après retrait de sa branche.

STAGING-ISOLATION utilise une identité lectrice réelle, découvre le candidat via métadonnées puis lit par URL signée. Cette sonde ne déclenche pas d'audit : le veto est testé séparément dans WAP-VETO. Supprimer la ref ne suffit pas à révoquer les objets ou URLs déjà accessibles. Le résultat porte sur la configuration testée.

Un grant table ne désigne pas une édition

Observation du banc · Les droits relationnels sont utiles, mais leur granularité doit correspondre à la frontière produit.

Le test AUTH montre grants et révocation au catalogue. Il ne prouve pas l'isolation des snapshots d'une même table. Une restriction de ligne/colonne ne peut pas protéger un utilisateur qui possède en parallèle un accès objet plus large.

Les métadonnées donnent accès à d'autres chemins

Écart constaté · Masquer une branche dans l'interface ne ferme pas l'accès aux fichiers.

Contrôler métadonnées, manifests, fichiers de données, delete files, statistiques et anciennes versions accessibles. Le signer doit vérifier le graphe de fichiers de l'édition autorisée, pas seulement l'appartenance au stockage de la table.

Porter l'identité jusqu'à l'accès effectif

Cible non qualifiée · Le tenant et la politique suivent la requête jusqu'aux données retournées.

Pas de service account partagé transformant implicitement toute requête en lecture administrateur. Qualifier token exchange, expiration, sessions longues et révocation. Les conditions TTL du modèle natif testé sont refusées.

Acceptation confidentialité

Avec identité non privilégiée, aucune récupération des objets hors édition autorisée, avant et après veto, suppression de branche et expiration.

Acceptation publication

Un worker compromis ou périmé ne peut pas publier main, changer un schéma global ni supprimer une table via son accès staging.

Sources détaillées dans l'HTML : Résultats AUTH et STAGING-ISOLATION · Modèle natif Lakekeeper 0.12.0.

Les mécanismes proposés ne sont pas des fonctionnalités déjà livrées. Rouge : comportement reproduit dans le banc local · Bleu : frontière proposée, encore à qualifier.